



CLOUDNATIVE
SECURITYCON

NORTH AMERICA 2024

JUNE 26-27 | SEATTLE, WA #CNSSCon

Cryptographic Lineage and Context

***Leveraging Cryptographic Lineage for Context and Connected
Trust for AI***



[Yogi Porla](#)

Led AI strategy and ops

Led Zero Trust Federation

Led Attested Claims dev team

Drove SPIFFE/SPIRE adoption



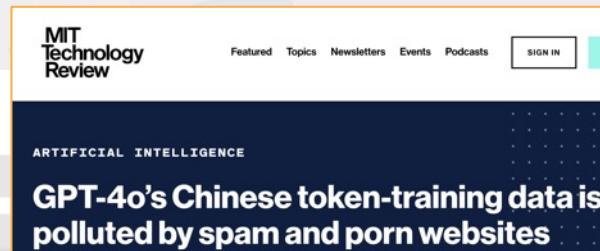
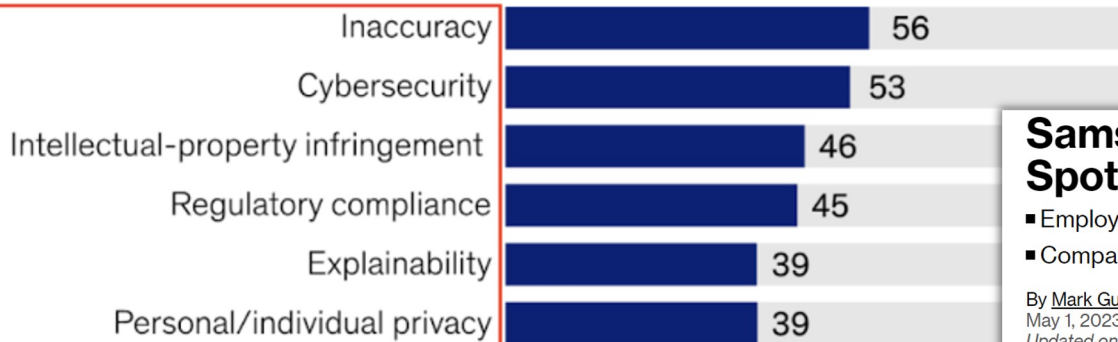
Key Takeaways

- 1) Security Challenges for Modern AI
- 2) Zero Trust and SPIFFE
- 3) Delegated Assertions and Context Awareness
- 4) Cryptographic Lineage and Attested Claims
- 5) Demo
- 6) Community and WIMSE working group



Enterprises are concerned about AI

Organization considers risk relevant



Samsung Bans Staff's AI Use After Spotting ChatGPT Data Leak

- Employees accidentally leaked sensitive data via ChatGPT
- Company preparing own internal artificial intelligence tools

By [Mark Gurman](#)
May 1, 2023 at 5:48 PM PDT
Updated on May 1, 2023 at 10:5

AI accountability: Who's responsible when AI goes wrong?

Just Security

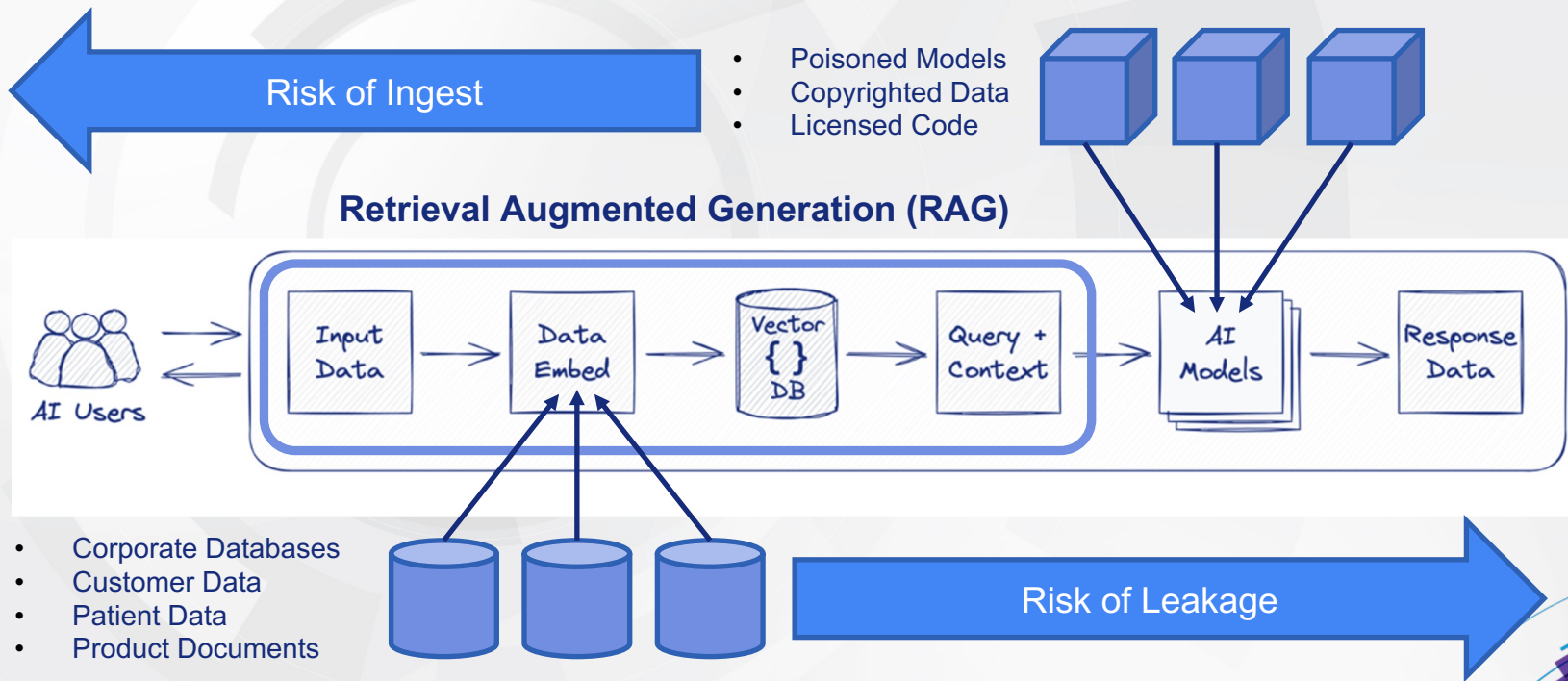
Biden's Executive Order on AI Gives Sweeping Mandate to DHS

The Biden administration's new executive order gives the DHS a wide-ranging portfolio of responsibilities related to artificial...





What has changed with advent of Gen AI?



Phased Approach towards Zero Trust AI



Point to Point Zero Trust

Chained Custody

Contextual Awareness

Attestation
Verification
Cert-Rotation

Secure Chain of Custody
Attested Claims

Context based Decisions
Intelligent Access Control

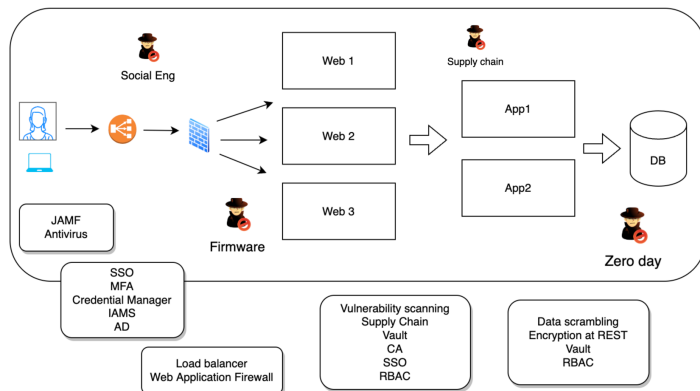
We are Here

Zero Trust and SPIFFE

What if attack occurs from inside?



Current Security Approach



Organizational policies: Training, MFA, Data Classification, GDPR, SLA 3+, Patching, Device Management

"We are trying to protect modern infrastructure with 20th century tools"

-Fred Kautz (CNCf, NSM, Anthem, Testifysec)

SPIFFE AND SPIRE PROJECTS



github.com/spiffe/spiffe

A set of specifications that cover how a workload should retrieve and use its identity.

- SPIFFE ID
- SPIFFE Verifiable Identity Documents (SVIDs)
- The SPIFFE Workload API



github.com/spiffe/spire

The SPIFFE Runtime Environment. Open-source software that implements the SPIFFE Workload API for a variety of platforms.

Apache 2.0 license. Independent governance. Highly extensible through plug-ins.

SPIFFE in two flavors: OSS and Commercial



SPIRE

- **Choose your own adventure**
 - Highly flexible, pluggable
 - Powerful building block
 - Attestation & issuance



SPIRL

- **Production ready out-of-the-box**
 - No databases required
 - Reporting, monitoring, SSO, etc
 - 24/7 enterprise support



SPIFFE OVERVIEW

Key Attributes

Short- lived credentials



Platform agnostic
Cloud and Container Ready



Automated



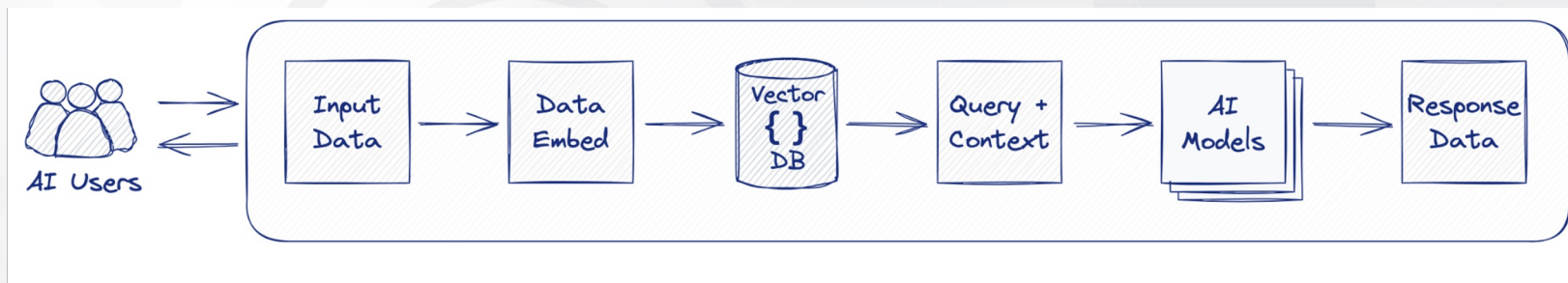
Cryptographic



API driven



Delegated Authentication Context



Non-Uniform Identity structures and formats create complexities and lost in Translation

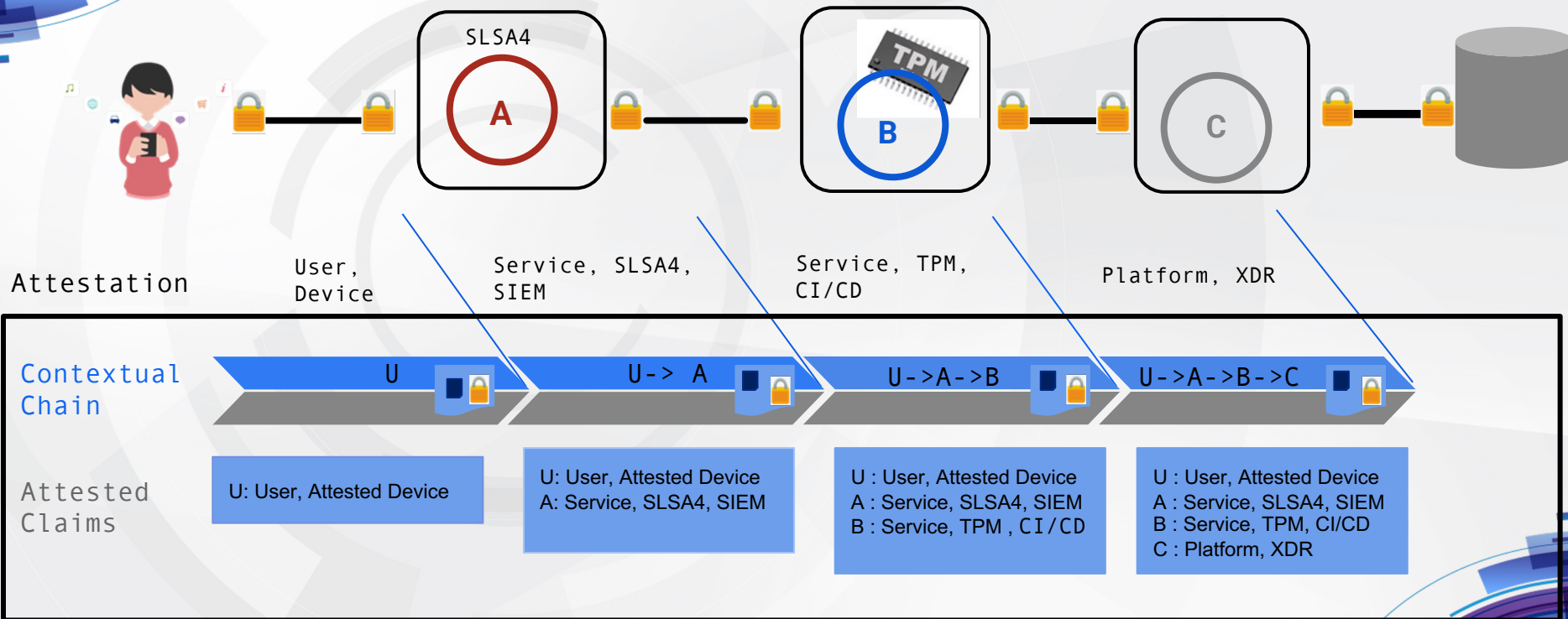
Workload receiving a message from another may wish to verify not only the identity of the calling workload but also that of a principal (such as a human end user) on behalf of which that message is being sent.

Context Awareness

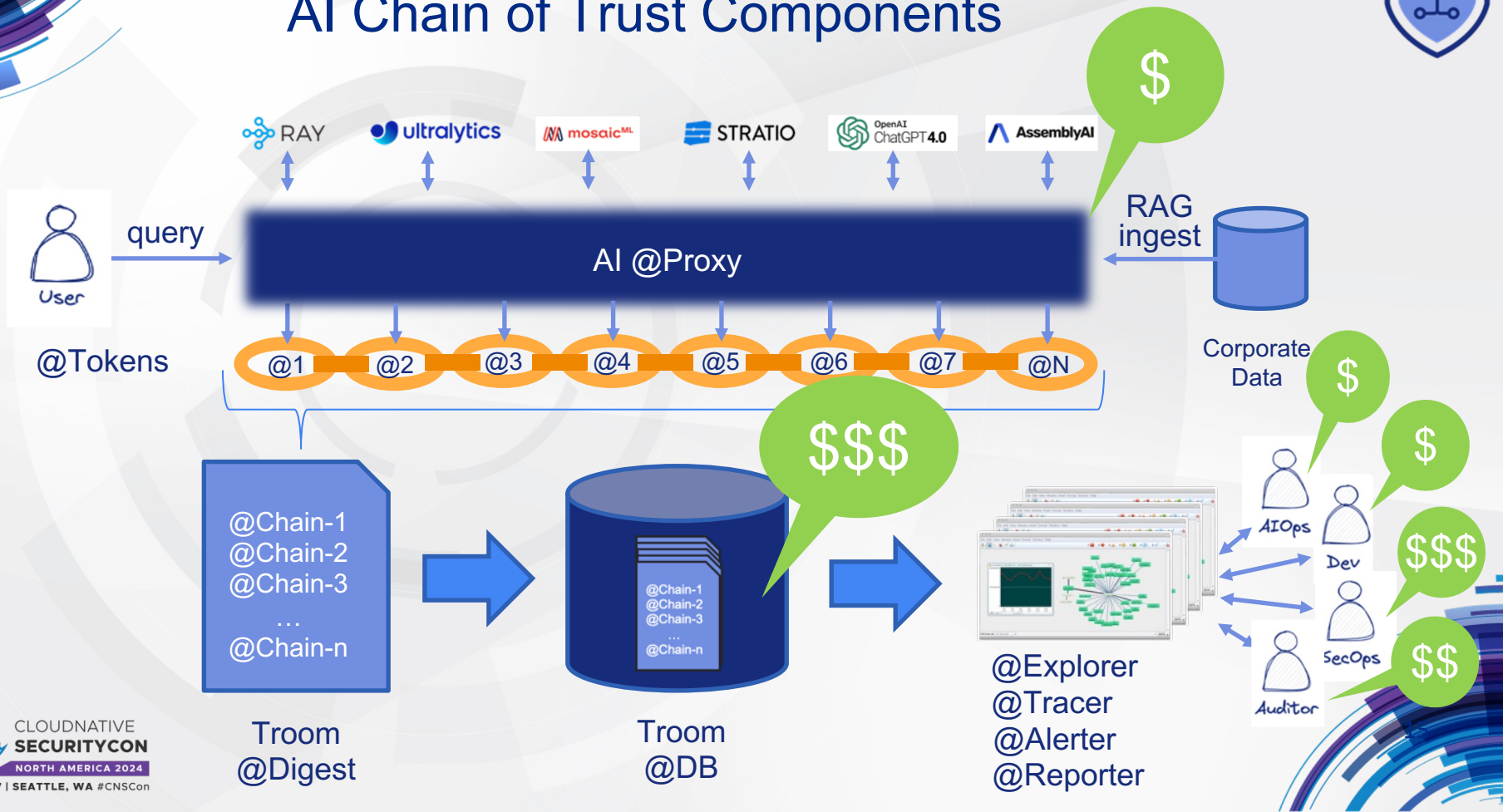


The cryptographically verified information carried through lineage and chain of custody is used for proactive security and leveraging Generative AI to create dynamic rules based on patterns for Context based Access.

Chain of Custody with Cryptographic Lineage

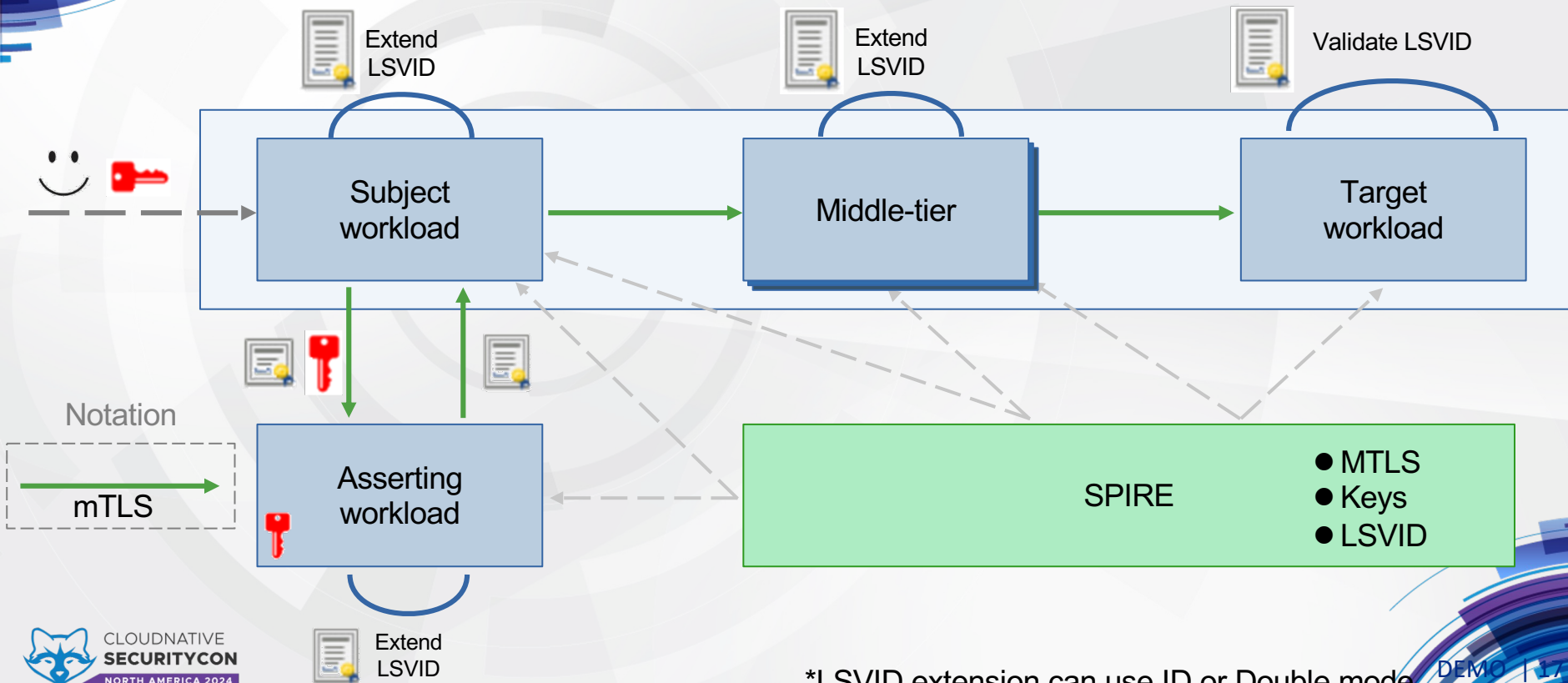


AI Chain of Trust Components



Demo

Demo Components



*LSVID extension can use ID or Double mode DEMO | 17

Collaboration Opportunities

DeepLineage Inc <https://deeplineage.io>

WIMSE working Group <https://datatracker.ietf.org/wg/wimse/about/>

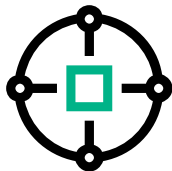
SPIFFE Attested Claims Working Group <https://spiffe.slack.com/archives/C03BS8JJYN4>

Ongoing community work on Attested Claims will act as a foundation for chain of custody and cryptographic Lineage. We productized this work to help organizations with deep rooted chain of custody and lineage.

Thanks



EXISTING SOLUTIONS HAVE THEIR LIMITATIONS



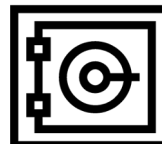
Network-based Access Tools

Assume the network is safe, and are unsuitable for dynamic environments



Legacy Protocols

Cannot be easily extended to the cloud or container-based environments.



Secret Stores

Require a secure introduction to services and create a “locus of privilege”

Rely on



spiffe



amazon

Anthem

arm

Bloomberg

ByteDance



coinbase

CONFLUENT

CRAY

cruise



Fidelity



Google

HashiCorp

Hewlett Packard
Enterprise

indeed

intel



JPMORGAN CHASE & CO.

PHILIPS



mastercard



NETFLIX



stripe



Uber

